

Threat Modelling Proyek Akhir Kelompok 8

Perancangan dan Implementasi Protokol Keamanan AAA

Pada Sistem Informasi Seekem

Muhammad Abyan Putra Wibowo	G6401231078
Muhammad Agung Rizkiansyah	G6401231096
Muhammad Chalied Al Walid	G6401231114

1. Pendahuluan

1.1 Tujuan

Dokumen ini bertujuan untuk mengidentifikasi, mengevaluasi, dan menanggulangi potensi kerentanan keamanan pada platform SEEKEM secara proaktif. Pemodelan ancaman ini memberikan panduan strategis untuk memastikan setiap fitur dirancang dengan menerapkan kontrol keamanan yang tepat (Security by Design).

1.2 Ruang Lingkup

Ruang lingkup pemodelan ancaman ini mencakup beberapa komponen utama, yaitu:

- Komponen antarmuka pengguna atau lapisan klien yang berfungsi sebagai aplikasi frontend.
- Sistem inti pada lapisan API yang mengelola logika backend, proses autentikasi, serta otorisasi hak akses.
- Lapisan penyimpanan data yang mengelola pelestarian informasi menggunakan basis data relasional.
- Layanan integrasi eksternal yang mencakup penggunaan penyimpanan awan untuk berkas media serta pemanfaatan webhook untuk kebutuhan notifikasi surel.

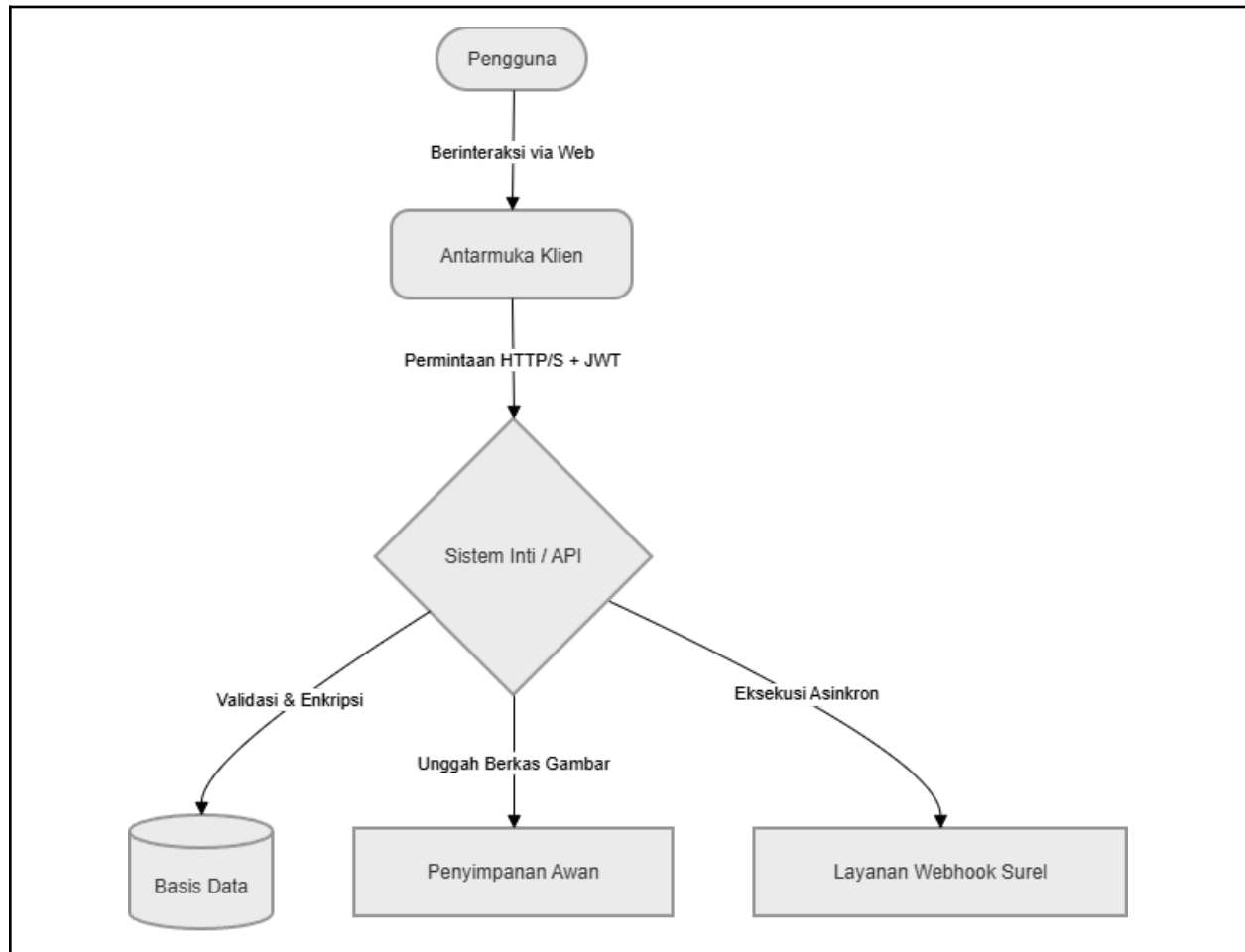
2. Identifikasi Aset Kritis

Aset-aset utama yang memiliki nilai kerahasiaan dan integritas tinggi dalam sistem ini meliputi:

1. Data identitas pribadi yang mencakup Nomor Induk Mahasiswa, nomor kontak, serta alamat surel institusi.
2. Kredensial dan data autentikasi yang terdiri atas kata sandi terenkripsi, JSON Web Token, serta token dinamis untuk pemulihan akses.
3. Data operasional yang berisikan rincian pelaporan barang hilang maupun barang temuan beserta foto bukti kepemilikan.
4. Catatan audit dan aktivitas yang merekam secara kronologis dan permanen atas seluruh tindakan pengguna beserta administrator di dalam sistem.
5. Kredensial infrastruktur peladen yang meliputi alamat URL Webhook, kunci layanan penyimpanan pihak ketiga, dan konfigurasi rute koneksi basis data.

3. Alur Data

Untuk mempermudah pemahaman pergerakan data di dalam sistem, berikut adalah diagram alir data SEEKEM:



Rincian Alir Data:

- Proses bermula saat pengguna berinteraksi dengan antarmuka klien berbasis web untuk melakukan berbagai kegiatan seperti pengisian formulir registrasi, akses masuk akun, pelaporan barang, maupun pengajuan klaim.
- Antarmuka klien secara otomatis mengirimkan instruksi terenkripsi yang telah disisipi oleh token autentikasi menuju server sistem inti melalui protokol komunikasi web.
- Server sistem inti bertanggung jawab untuk memvalidasi masukan, mengenkripsi data identitas pribadi pengguna, dan menyimpannya secara terstruktur ke dalam basis data bersamaan dengan pencatatan rekam jejak aktivitas.
- Server sistem inti juga berinteraksi dengan layanan pihak ketiga untuk meneruskan unggahan berkas foto ke media penyimpanan awan serta memicu perintah pengiriman notifikasi surel secara asinkron.

4. Identifikasi Aktor Ancaman

Berikut adalah identifikasi pihak-pihak yang berpotensi menjadi sumber ancaman bagi sistem:

Aktor Ancaman	Motivasi	Contoh Ancaman
Pengguna Internal (Civitas Akademika)	Keuntungan finansial/pribadi, manipulasi data, atau kelalaian.	Mengklaim barang berharga yang bukan miliknya, memanipulasi request pelaporan, atau tidak sengaja membagikan token aksesnya.
Pihak Eksternal Tak Berwenang	Vandalisme, pencurian data privasi (nomor telepon), atau spamming.	Melakukan serangan Denial of Service (DoS) ke peladen, atau mengeksploitasi celah untuk mencuri daftar kontak pengguna.
Administrator Nakal (Rogue Admin)	Penyalahgunaan kewenangan, menutupi jejak kecurangan.	Menyetujui klaim untuk menguntungkan diri sendiri, atau mencoba menghapus dan memodifikasi riwayat Audit Logs di basis data.

5. Implementasi Kerangka Keamanan AAA

Sistem SEEKEM membutuhkan pengamanan data dan identitas secara komprehensif melalui kerangka kerja keamanan AAA:

5.1 Authentication (Autentikasi)

Memastikan identitas pengguna yang mengakses sistem valid dan dapat dipertanggungjawabkan.

- Penerapan verifikasi identitas awal pada saat registrasi akun yang dikhususkan bagi civitas akademika melalui simulasi domain Single Sign-On (@apps.ipb.ac.id), di mana pengguna diwajibkan melakukan verifikasi surel melalui tautan token dengan masa aktif selama dua puluh empat jam sebelum mendapatkan akses.
- Pengelolaan sesi yang mengautentikasi setiap permintaan akses ke sistem inti di tingkat server dengan menggunakan skema Bearer Token berbasis JSON Web Token untuk memastikan kelayakan pengguna yang bersangkutan.
- Pelaksanaan proses pemulihan akses secara aman saat pengguna mengatur ulang kata sandi dengan memanfaatkan tautan dinamis berbasis token satu kali pakai yang memiliki batas kedaluwarsa selama lima belas menit.

5.2 Authorization (Otorisasi)

Mengontrol hak akses setiap identitas sesuai dengan prinsip hak istimewa terkecil (Principle of Least Privilege) dan batasan peran (Role-Based Access Control / RBAC).

- Penerapan pembatasan peran menggunakan dua entitas hak akses yang ketat, yaitu pengguna umum dan administrator, disertai pembatasan sistemik yang melarang administrator untuk membuat klaim maupun laporan publik demi menjaga netralitas platform.
- Perlindungan fungsionalitas sistem yang memperbolehkan rute publik diakses secara bebas, namun mewajibkan pelampiran token autentikasi yang sah untuk setiap rute modifikasi data, serta

mengunci akses ke dasbor verifikasi secara eksklusif hanya untuk pengguna dengan tingkat otorisasi administrator.

- Pemisahan logika aplikasi dan perlindungan privasi yang dilakukan dengan menolak penyisipan atribut yang tidak sah guna mencegah pengguna meningkatkan perannya secara sepihak, serta merahasiakan nomor kontak pengguna hingga klaim dinyatakan sah oleh pihak pengelola.

5.3 Authentication (Autentikasi)

Melacak, mencatat, dan mengaudit setiap tindakan penting yang terjadi di dalam sistem guna mencegah penyangkalan dan menjaga integritas platform.

- Pencatatan aktivitas seluruh transaksi fungsional di dalam sistem, seperti pembuatan pelaporan maupun pengajuan klaim barang, yang direkam secara kronologis mencakup identitas aktor pelaksana, jenis aksi, serta stempel waktu terjadinya transaksi.
- Perekaman jejak audit kriptografi untuk aksi-aksi kritikal di tingkat server yang senantiasa dibubuhkan tanda tangan kriptografi saat disimpan ke dalam basis data, dengan tujuan utama untuk mendeteksi dan mencegah pengubahan riwayat aktivitas secara ilegal.
- Pelaksanaan enkripsi data sensitif sebagai perlindungan tambahan pada semua informasi identitas pribadi menggunakan metode enkripsi simetris berbasis algoritma Fernet di dalam lapisan basis data.

6. Analisis Ancaman dan Mitigasi (Kerangka STRIDE)

Kategori STRIDE	Ancaman (Threat)	Dampak (Impact)	Mitigasi
Spoofing	Pendaftaran dengan identitas/email palsu atau pembajakan sesi.	Klaim barang curang oleh pihak tak bertanggung jawab.	Verifikasi email @apps.ipb.ac.id. Autentikasi ketat via JWT tersandi.
Tampering	Memanipulasi request untuk ubah status laporan, atau bypass Audit Logs.	Integritas data cacat & audit kehilangan fungsi.	Validasi Pydantic & injeksi Cryptographic Signature pada Logs.
Repudiation	Menyangkal telah melakukan laporan atau klaim barang.	Perselisihan serah terima tanpa bukti.	Pencatatan kronologis permanen di Activity & Audit Logs (beserta IP).
Information Disclosure	Bocornya kontak WhatsApp pengguna atau kredensial server.	Pelanggaran privasi PII (Personally Identifiable Information) atau eksploitasi sistem (Takeover).	Enkripsi Fernet untuk PII di DB. Isolasi mutlak konfigurasi .env.
Denial of Service	Spamming request (login/email) secara masif.	Server tumbang & kuota email harian habis.	Rate Limiting API & asinkronisasi pengiriman email.

Elevation of Privilege	Menyisipkan modifikasi hak akses (mis. role: admin) dari klien.	Pengguna biasa bisa memverifikasi laporan miliknya sendiri.	Proteksi Mass Assignment & otorisasi lapis ganda Admin.
-------------------------------	---	---	---

7. Matriks Risiko

Berikut adalah pemetaan tingkat risiko keamanan berdasarkan tingkat kemungkinan (Likelihood) dan dampak (Impact) pasca implementasi strategi mitigasi:

Ancaman (Kategori)	Kemungkinan (Likelihood)	Dampak (Impact)	Tingkat Risiko Akhir
Spoofing	Rendah	Tinggi	Sedang
Tampering	Sangat Rendah	Tinggi	Rendah
Repudiation	Rendah	Sedang	Rendah
Information Disclosure	Rendah	Sangat Tinggi	Sedang
Denial of Service	Sedang	Sedang	Sedang
Elevation of Privilege	Sangat Rendah	Sangat Tinggi	Rendah

8. Kesimpulan

Implementasi perlindungan berlapis (Defense in Depth) pada SEEKEM, seperti validasi data kaku, proteksi Rate Limiting, penandatanganan Cryptographic Signature pada log, serta enkripsi PII (Personally Identifiable Information), memastikan risiko kerentanan tetap berada pada batas toleransi yang dapat dikelola. Hal ini memastikan keamanan platform bagi civitas akademika IPB University.